WEEK 10 — TESTING, DEBUGGING & QUALITY ASSURANCE

Bug Report

Course	CSE 4104 — Software Development III
Team	CSE4104-7C-T05
Project Title	AI Academic Mentor
Instructor	Md. Riaz Mahmud, Assistant Professor, Dept. of CSE, NUBTK
Section	7C
Submission Date	07 September 2026
GitHub Repository Link	GitHub - Priyo-1158/cse4104-7c-t05-ai-academic-mentor: AI Academic Mentor - Personalized Learning Assistant for Students · GitHub

Team Information

Role	Member Name	Student ID	Contribution
Team Leader	Shadman Sadequeen Priyo	11230121158	Project coordination, GitHub management, integration testing
Frontend Developer	Musabbir Hossain Chayon	11230121168	React/Vite UI, API wiring, report authoring, deployment
Backend Developer	Sk. Nadirul Haque Nadir	11230121155	Express routes, MongoDB models, JWT authentication
AI Integration Lead	Shafin Kabir	11230121175	Gemini/HuggingFace routes, prompt design

1. BUG SUMMARY

ID	Title	Severity	Status
BUG-01	Reflected XSS: raw text rendered via dangerouslySetInnerHTML with no HTML escaping	Critical	OPEN
BUG-02	Live production secrets found shipped inside a previously submitted project archive	Critical	OPEN
BUG-03	All AI features (chat/quiz/plan/summary) are 100% non-functional — invalid Gemini key format	Critical	OPEN
BUG-04	Admin & Notes routes crash with raw internal errors when MongoDB is unreachable	High	OPEN
BUG-05	AI-specific rate limiter is declared but never mounted (dead code)	High	OPEN
BUG-06	Production API base URL is still a placeholder	High	OPEN
BUG-07	Quiz/Planner/Summarizer bypass their own dedicated backend endpoints	High	OPEN
BUG-08	Admin user-update endpoint skips schema validation, allowing an invalid role value	Medium	OPEN
BUG-09	Notes/Plan update endpoints accept unrestricted request bodies (mass assignment)	Medium	OPEN
BUG-10	Expired JWT is not detected client-side; UI silently stays "logged in"	Medium	OPEN
BUG-11	GitHub repository URL is still a placeholder in README.md	Medium	OPEN
BUG-12	Login, Register, and Notifications pages have zero responsive breakpoints (code-level)	Low	OPEN
BUG-13	CORS-blocked requests return HTTP 500 instead of HTTP 403	Low	OPEN

2. DETAILED BUG RECORDS

CRITICAL SEVERITY

BUG-01 CRITICAL

Reflected XSS via unescaped AI reply rendering

MODULE	SEVERITY	STATUS	BUG ID
Frontend — Chatbot.jsx, Summarizer.jsx, utils/helpers.js	Critical	Open	BUG-01

Description

AI chat and summarizer replies are rendered with React's dangerouslySetInnerHTML, passed through a formatMarkdown() helper that converts **bold**/*italic*/`code` to HTML — but never escapes the raw text first. An escapeHtml() function already exists in the same file and is never called from formatMarkdown(). Since the backend's AI fallback text echoes the user's own message back into the reply (see BUG-03), any HTML a user types can end up executed in their own browser DOM.

Steps to Reproduce

1. Open the Chatbot page (or Summarizer) and send the message: <script>alert(1)</script> && DROP TABLE users;
2. The backend returns { reply: "### Academic Insight on: <SCRIPT>ALERT(1)</SCRIPT> && DROP TABLE USERS; ..." } — confirmed via direct curl to /api/ai/chat (test case AI-12).
3. The frontend renders this string through formatMarkdown(reply) and injects the result via dangerouslySetInnerHTML.
4. Because formatMarkdown() never calls escapeHtml(), the <script> tag is inserted into the live DOM as a real element, not as visible text.

EXPECTED BEHAVIOR

Any HTML characters in AI-generated or user-echoed text are escaped before being converted to formatted HTML, so a payload like <script> renders as literal visible text, never as an executable tag.

ACTUAL BEHAVIOR

The raw <script> tag is preserved unescaped all the way into dangerouslySetInnerHTML — a textbook DOM-based XSS sink with an unsanitized source. Confirmed at the API layer (test AI-12); rendering in an actual browser DOM is [REQUIRES ACTUAL TESTING] to visually confirm script execution, since no browser was available in this sandbox.

Evidence

```
$ curl -s -X POST localhost:5000/api/ai/chat -H "Content-Type:
application/json" \
  -d '{"messages":[{"role":"user","content":"<script>alert(1)</script> &&
DROP TABLE users;"}]}'

{"reply":"### Academic Insight on: <SCRIPT>ALERT(1)</SCRIPT> && DROP TABLE
USERS; ..."}

// utils/helpers.js — escapeHtml() exists but formatMarkdown() never calls
it:
export function formatMarkdown(text) {
  return (text || '')
    .replace(/\*\*(.+?)\*\*/g, '<strong>$1</strong>')   // operates on RAW
text
    ...
```

Suggested Resolution

In formatMarkdown(), call escapeHtml(text) first, then run the bold/italic/code replacements on the escaped string. Apply the same fix everywhere else dangerouslySetInnerHTML is used (Summarizer.jsx line ~162).

BUG-02 CRITICAL

Live production secrets shipped inside a submission archive

MODULE	SEVERITY	STATUS	BUG ID
Backend — backend/.env	Critical	Open	BUG-02

Description

A previously submitted archive of this project includes backend/.env with real, working credentials: a full MongoDB Atlas connection string with username and password, a JWT signing secret, a Gemini API key, a HuggingFace access token, and the server-side admin signup code. backend/.gitignore correctly excludes .env from git commits, but that protection only applies to git — it does nothing to stop the file being zipped up directly for submission, which is what happened.

Steps to Reproduce

1. Unzip the previously submitted archive and inspect backend/.env.
2. Observe MONGODB_URI containing a live username:password pair for the team's Atlas cluster.
3. Observe JWT_SECRET, GEMINI_API_KEY, HF_ACCESS_TOKEN, and ADMIN_ACCESS_CODE all present in plaintext.
4. Anyone who receives this archive now has full read/write access to the team's live database and can mint valid admin JWTs by re-signing tokens with the leaked secret.

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
Only backend/.env.example (with placeholder values) should ever leave the team's machines.	The real, working .env with five live secrets was present in the archive.

Suggested Resolution

Rotate all five secrets (MongoDB password, JWT secret, Gemini key, HF token, admin code). Delete backend/.env from the working copy before rebuilding the submission archive, or build the archive from a fresh git clone so .gitignore excludes it automatically.

BUG-03 CRITICAL

All AI features are 100% non-functional — invalid Gemini API key format

MODULE	SEVERITY	STATUS	BUG ID
Backend — routes/ai.js, backend/.env	Critical	Open	BUG-03

Description

GEMINI_API_KEY in .env is "AQ.Ab8RN6J2...". Real Gemini Developer API keys from Google AI Studio always start with "AIza"; a key starting "AQ." is shaped like a short-lived Google OAuth access token, not a Developer API key, and cannot authenticate a generateContent call. 12 separate live test inputs (AI-01 through AI-12) were sent for this report; all 12 fell through to the static local fallback with zero live AI-generated content.

Steps to Reproduce

1. Send any request to POST /api/ai/chat, /api/ai/quiz, /api/ai/plan, or /api/ai/summarize.
2. Observe the Gemini call fail server-side (visible in server logs as "GEMINI ERROR").
3. Observe the response body's "source" field reads "Static Fallback (both AI providers unavailable)" on all 12 tested inputs (AI-01–AI-12).
4. For Quiz and Study Plan specifically (AI-10, AI-11), observe HTTP 200 with an empty array because the static fallback text is not valid JSON.

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
A syntactically valid Gemini key (AIza-prefixed) should let genuine, topic-relevant AI content come back for all four features.	Zero of the 12 requests received a real AI-generated response.

Evidence

```
GEMINI_API_KEY=AQ.Ab8RN6J2TomSJnA7GIlbc_cRhqWlTit2rHOA6pnYaxvtfVgReQ   // wrong format
// real keys look like: AIzaSyXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
```

```
const GEMINI_KEY_LOOKS_VALID =
  typeof process.env.GEMINI_API_KEY === "string" &&
  process.env.GEMINI_API_KEY.trim().length > 0;   // never checks the "AIza"
prefix
```

Suggested Resolution

Generate a real key at https://aistudio.google.com/app/apikey and replace GEMINI_API_KEY. Fix GEMINI_KEY_LOOKS_VALID to check .startsWith("AIza"). Re-run test cases AI-01 through AI-12 after the fix — this whole table must be redone with a working key, not just spot-checked.

HIGH SEVERITY

BUG-04 HIGH

Admin and Notes routes crash with raw internal errors when MongoDB is unreachable

MODULE	SEVERITY	STATUS	BUG ID
Backend — routes/admin.js, routes/notes.js	High	Open	BUG-04

Description

Every other resource route (auth, quiz, plan, summary) checks isDbConnected() and falls back to a clean demo mode when Mongo isn't reachable. admin.js and notes.js skip this check and query Mongoose directly, so when the DB is down they throw uncaught exceptions that leak straight into the HTTP response as raw internal text.

Steps to Reproduce

1. With MongoDB disconnected, call GET /api/admin/stats as an admin (test case TC-18).
2. Observe HTTP 500 with a raw Mongoose buffering-timeout message.
3. Call GET /api/notes/:id with any id (test cases TC-31, TC-32).
4. Observe HTTP 500 with the exact Mongoose schema path exposed to the client.

EXPECTED BEHAVIOR

Admin and Notes endpoints degrade the same way every other route does: a clean 200 with an empty/demo dataset, or at worst a clean 503, never a raw internal error string.

ACTUAL BEHAVIOR

Both modules return HTTP 500 with internal Mongoose details exposed in the response body.

Suggested Resolution

Add the same isDbConnected() guard used in auth.js/quiz.js/plan.js/summary.js to admin.js and notes.js.

BUG-05 HIGH

AI-specific rate limiter is declared but never mounted

MODULE	SEVERITY	STATUS	BUG ID
Backend — server.js	High	Open	BUG-05

Description

server.js defines an aiLimiter (60 requests/minute) intended to throttle the AI endpoints specifically. It is never attached to the /api/ai router anywhere in the file — it is dead code.

Steps to Reproduce

1. grep -rn "aiLimiter" backend/ — the only match is its own declaration in server.js.
2. AI requests in a tight loop are only ever throttled by the generic 100-per-15-minutes limiter, never a 60-per-minute AI-specific one.

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
POST /api/ai/* requests are throttled at 60/minute as the code's own naming clearly intends.	No AI-specific throttling exists at all in the running server.

Suggested Resolution

Mount it where the AI router is registered: app.use('/api/ai', aiLimiter, require('./routes/ai'));

BUG-06 HIGH

Production API base URL is still the literal placeholder

MODULE	SEVERITY	STATUS	BUG ID
Frontend — src/services/api.js	High	Open	BUG-06

Description

PRODUCTION_API_BASE is hardcoded to 'https://YOUR-BACKEND.onrender.com' — a domain that does not exist. Any build accessed from somewhere other than localhost will try to reach this fake domain for every API call.

Steps to Reproduce

1. Build the frontend for production and open it from any hostname other than localhost.
2. Attempt any feature — every request targets the non-existent placeholder domain and fails.

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
The deployed frontend reaches the team's actual deployed backend URL.	The deployed frontend is non-functional beyond the login screen for anyone not running it locally.

Suggested Resolution

Set VITE_API_BASE in the frontend's deployment environment to the real backend URL; replace the placeholder fallback string once a real URL exists.

BUG-07 HIGH

Quiz, Planner, and Summarizer bypass their own dedicated backend endpoints

MODULE	SEVERITY	STATUS	BUG ID
Frontend — pages/Quiz.jsx, Planner.jsx, Summarizer.jsx	High	Open	BUG-07

Description

The backend has purpose-built endpoints POST /api/ai/quiz, /api/ai/plan, /api/ai/summarize with matching helper functions in aiApi.js. None of the three pages call them — each builds its own prompt client-side and posts it to the generic /api/ai/chat instead, then hand-parses JSON from the reply.

Steps to Reproduce

1. grep -n "GeminiAPI\." across Quiz.jsx, Planner.jsx, Summarizer.jsx.
2. Observe all three call only GeminiAPI.call(prompt) (→ /api/ai/chat), never .generateQuiz(), .generatePlan(), or .summarize().

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
Each feature calls its matching purpose-built endpoint.	Three duplicated, hand-rolled prompt implementations exist client-side while three working backend endpoints sit unused.

Suggested Resolution

Swap each page to call its matching GeminiAPI helper instead of building raw prompts against .call().

MEDIUM SEVERITY

BUG-08 MEDIUM
Admin user-update endpoint skips schema validation

MODULE	SEVERITY	STATUS	BUG ID
Backend — routes/admin.js	Medium	Open	BUG-08

Description

PUT /api/admin/users/:id omits { runValidators: true }, so the User schema's role enum is not enforced on this update path.

Steps to Reproduce

1. Call PUT /api/admin/users/:id with { "role": "superadmin" } as an admin (test case TC-34).
2. Blocked from full end-to-end confirmation in this sandbox because MongoDB is unreachable — TC-34 fails on the DB connection itself before reaching this validation gap, confirmed structurally via source review only.

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
Any role value outside ['student', 'admin'] is rejected with a validation error.	The enum constraint is silently skipped on this specific update path — [VERIFY BUG DURING ACTUAL TESTING] against a live database to see the invalid value actually persist.

Suggested Resolution

Add { new: true, runValidators: true } to the findByIdAndUpdate call.

BUG-09 MEDIUM
Notes and Plan update endpoints accept unrestricted request bodies

MODULE	SEVERITY	STATUS	BUG ID
Backend — routes/notes.js, routes/plan.js	Medium	Open	BUG-09

Description

PUT /api/notes/:id and PUT /api/plan/:id pass req.body directly into findOneAndUpdate with no field allow-list, unlike summary.js and quiz.js which explicitly destructure only allowed fields.

Steps to Reproduce

1. Compare notes.js/plan.js PUT handlers against summary.js/quiz.js PUT handlers.
2. [REQUIRES ACTUAL TESTING] against a live database to confirm an unexpected field is actually persisted.

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
Only an explicit allow-list of fields can be updated by the client.	notes.js and plan.js accept the entire request body verbatim.

Suggested Resolution

Destructure only the intended fields before calling findOneAndUpdate, matching the pattern already used in quiz.js and summary.js.

BUG-10 MEDIUM

Expired JWT is not detected client-side

MODULE	SEVERITY	STATUS	BUG ID
Frontend — src/contexts/AuthContext.jsx	Medium	Open	BUG-10

Description

isLoggedIn is computed purely as !!user?.token — token presence, not validity. Nothing listens for a 401 "token expired" response and clears the session automatically.

Steps to Reproduce

1. Log in, then wait for (or simulate) JWT expiry.
2. Reload any protected page — it still renders as logged in.
3. [REQUIRES ACTUAL TESTING] in a real browser to confirm the on-screen behavior; confirmed at the code level only.

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
A 401 expired-token response triggers an automatic logout and redirect to /login.	The session silently persists in the UI until an API call happens to fail.

Suggested Resolution

In the axios response interceptor, detect 401 and call logout() before rejecting.

BUG-11 MEDIUM

GitHub repository URL is still a placeholder

MODULE	SEVERITY	STATUS	BUG ID
Documentation — README.md	Medium	Open	BUG-11

Description

The assignment brief requires a working GitHub repository link. README.md still contains the literal unfilled placeholder text.

Steps to Reproduce

1. Open README.md.
2. Find: Repository: `<PASTE YOUR GITHUB REPO URL HERE>`.

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
A working link to the team's actual repository.	A placeholder string, not a link.

Suggested Resolution

Replace the placeholder with the real repository URL in README.md and in Section 24 of the Testing Report.

LOW SEVERITY

BUG-12 LOW

Login, Register, and Notifications pages have zero responsive breakpoints

MODULE	SEVERITY	STATUS	BUG ID
Frontend — Login.css, Register.css, Notifications.css	Low	Open	BUG-12

Description

grep -c "@media" across every page-level stylesheet returns 0 for these three files and ≥1 for every other page. This is a code-level signal only — no device screenshot confirms the actual on-screen breakage.

Steps to Reproduce

1. grep -c "@media" src/pages/*.css
2. Login.css: 0, Register.css: 0, Notifications.css: 0 — every other file: 1 or more.
3. [REQUIRES ACTUAL TESTING] on a real device/emulator to confirm visible breakage.

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
Consistent responsive coverage across every page.	The two entry-point pages of the app (and the notification panel) have no responsive rules at all.

Suggested Resolution

Add at least one ≤768px breakpoint to Login.css and Register.css, matching the pattern in Dashboard.css.

BUG-13 LOW

CORS-blocked requests return HTTP 500 instead of HTTP 403

MODULE	SEVERITY	STATUS	BUG ID
Backend — server.js	Low	Open	BUG-13

Description

The CORS origin callback correctly blocks disallowed origins but does so by throwing an Error, which Express surfaces as a generic 500 rather than a 403.

Steps to Reproduce

1. Send a request with Origin: https://evil-site.com to any endpoint (test cases TC-35, TC-36).
2. Observe the request is correctly blocked, but with HTTP 500, not HTTP 403.

EXPECTED BEHAVIOR	ACTUAL BEHAVIOR
A blocked cross-origin request returns HTTP 403 Forbidden.	It returns HTTP 500 Internal Server Error.

Suggested Resolution

Respond directly with a 403 in the CORS origin callback rather than letting a thrown Error fall through to the generic error handler.

3. REGRESSION TESTING SUMMARY

No fixes have been merged yet, so a formal post-fix regression pass is not yet applicable. Once any bug above is fixed, the team must re-run: (a) the bug's own reproduction steps, and (b) the full authentication/RBAC suite (TC-01–TC-19), since several of these bugs (BUG-04, BUG-08) sit in routes adjacent to authentication and authorization logic.

4. REMAINING OPEN BUGS

All 13 bugs identified in this report remain OPEN as of the report date. Priority order for a team with limited time before submission:

- Fix first: BUG-02 (rotate leaked secrets), BUG-01 (XSS), BUG-03 (AI key) — all three are Critical and directly affect submission safety and the core feature.
- Fix next: BUG-04, BUG-06, BUG-11 — quick, high-value fixes (a missing guard, an env var, a README edit).
- Fix if time allows: BUG-05, BUG-07, BUG-08, BUG-09, BUG-10, BUG-12, BUG-13.